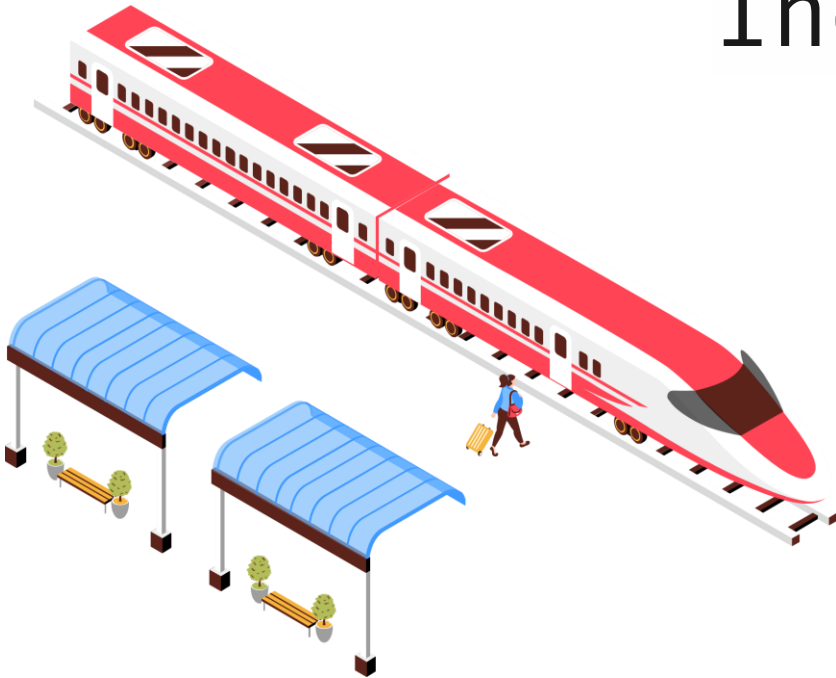


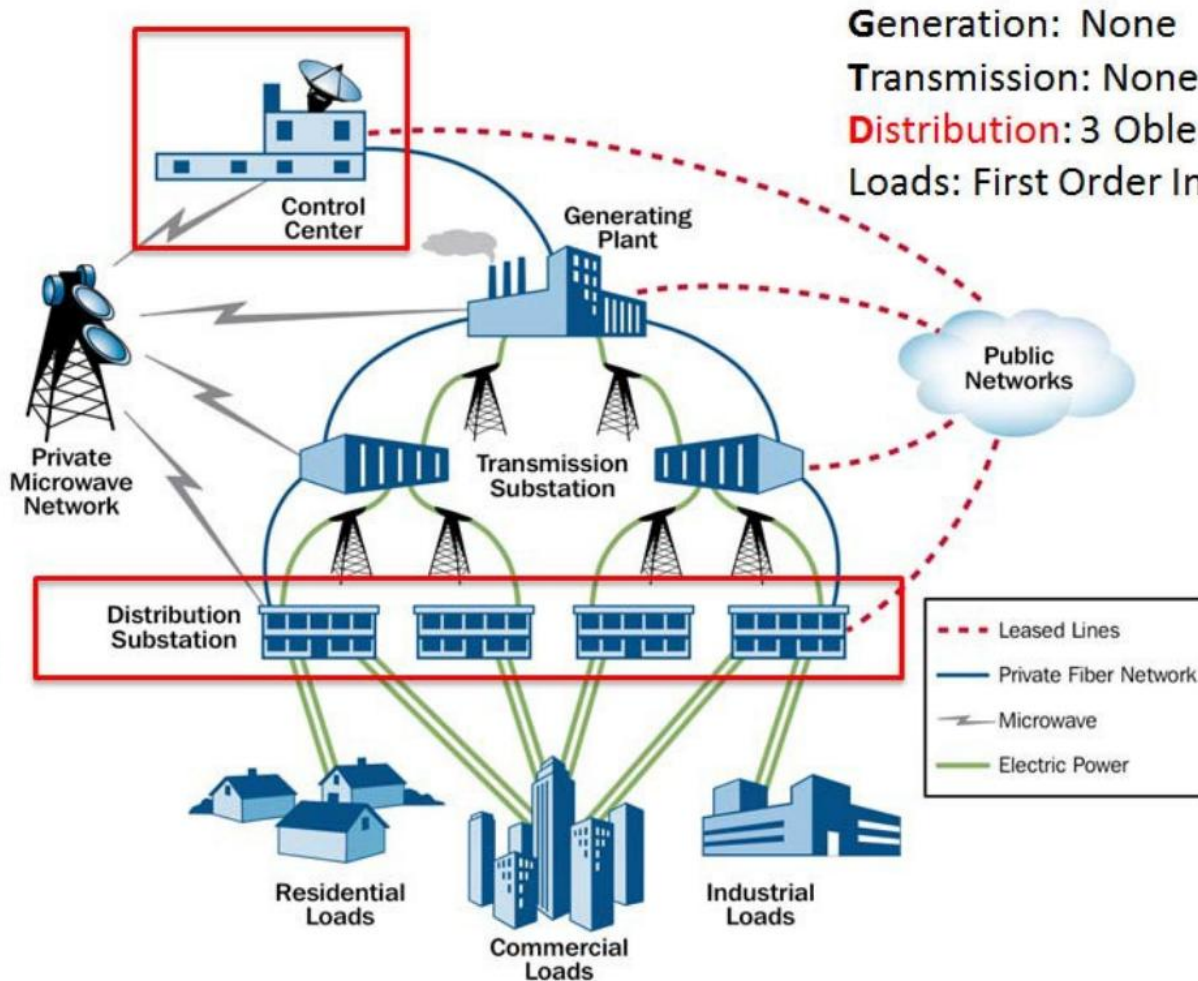
Cyber-security in Industrial Control Systems



**Kawtar Zerhouni, Maîtresse de conférences
UTER MID@S - ECC**



... Vulnerabilities around the world



Generation: None
Transmission: None
Distribution: 3 Oblenergos
Loads: First Order Impacts



Date: December 23, 2015

Location: Ukraine

Target: Three Ukrainian heat and electricity distribution companies

Cyberattack:

- Attack on **SCADA** distribution management system (DMS)
- Control of Human-Machine Interfaces (HMI)
- Disabling of field communications

Impact:

- **225,000** customers lost power
- At least 27 substations were reported offline



... Vulnerabilities around the world

ICS/OT

Train Brakes Can Be Hacked Over Radio—And the Industry Knew for 20 Years

A vulnerability affecting systems named End-of-Train and Head-of-Train can be exploited by hackers to cause trains to brake.



By [Eduard Kovacs](#) | July 14, 2025 (11:05 AM ET)
Updated: July 15, 2025 (12:25 AM ET)

SecurityWeek, **July 2025**

→ SDR-grade radio spoofing can trigger emergency braking.

SDR: Software Defined Radio.



... Vulnerabilities around the world

ICS/OT

Train Brakes Can Be Hacked Over Radio—And the Industry Knew for 20 Years

A vulnerability affecting systems named End-of-Train and Head-of-Train can be exploited by hackers to cause trains to brake.



By [Eduard Kovacs](#) | July 14, 2025 (11:05 AM ET)
Updated: July 15, 2025 (12:25 AM ET)

Critical Infrastructure

Industrial Cyber Attacks

Malware, Phishing & Ransomware

News

Transportation

Ukraine's Ukrzaliznytsia railway operator hit by cyberattack; ticket system disrupted sparking long queues

MARCH 25, 2025

*Industrial Cyber, **March 2025***

→ Malware disrupted operations, showing IT→OT vulnerability.



... Vulnerabilities around the world

ICS/OT

Train Brakes Can Be Hacked Over Radio—And the Industry Knew for 20 Years

A vulnerability affecting systems named End-of-Train and Head-of-Train can be exploited by hackers to cause trains to brake.



By [Eduard Kovacs](#) | July 14, 2025 (11:05 AM ET)
Updated: July 15, 2025 (12:25 AM ET)

[Critical Infrastructure](#) [Industrial Cyber Attacks](#) [Malware, Phishing & Ransomware](#) [News](#) [Transportation](#)

Ukraine's Ukrzaliznytsia railway operator hit by cyberattack; ticket system disrupted sparking long queues

MARCH 25, 2025

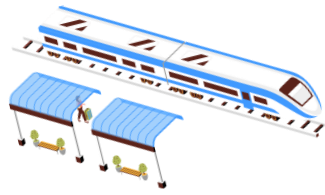
DENMARK AND NORWAY INVESTIGATE YUTONG BUS SECURITY FLAW AMID RISING TECH FEARS

Pierluigi Paganini November 10, 2025

*Security Affairs, **Nov 2025***

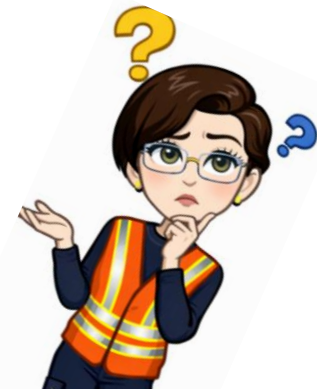
→ Hidden remote-access channel detected in imported vehicles.

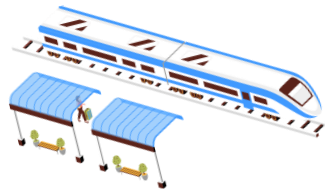
What can we learn from these examples?



- Industrial control systems (ICS) control physical processes.
- **Breaches of cyber-physical systems** can lead to **physical impacts**, potentially causing **unsafe system operation, injury**, and **loss of life**.
- ICS cybersecurity encompasses various concepts, engineering methods, and technologies.
- Some aspects are **specific to the industrial domain**, while others are applicable to related fields.
- Unique aspects stem from the **integration** of embedded computers, sensors, and networking components.

→ How can we cover all of this within a 16-hour timeframe?





Lecture 1 : Industrial & OT Systems and Security Fundamentals

Lecture 2 : Threats, Vulnerabilities and Risk in OT/ICS

What exactly are we aiming to safeguard ICS systems against?

Lecture 3 : Incident Response and Resilience in OT

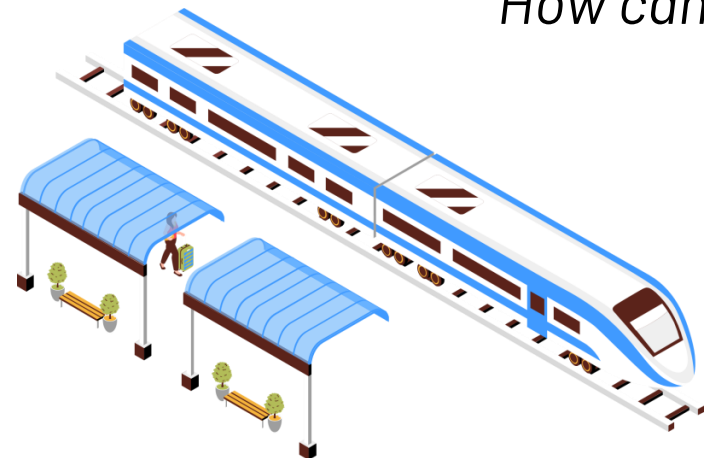
What actions should we take in the event of an incident?

Lecture 4 : Security Monitoring and AI

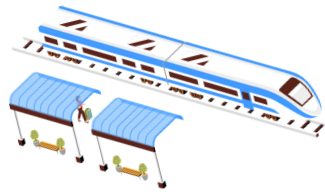
How can we prevent incidents ?

Evaluation:

- 2 tutorials / lab deliverables (technical exploration).
- 1 short mini-project



Main References for the Course



Textbooks

- Pascal Ackerman, *Industrial Cybersecurity: Efficiently Monitor the Cybersecurity Posture of Your ICS Environment*, 2nd Edition, Packt, 2021.
- Jean-Marie Flaus, *Cybersecurity of Industrial Systems*, Wiley, 2019.

Official Guidance and Frameworks

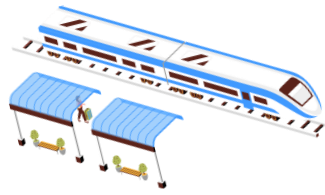
- **NIST SP 800-82 Revision 3 – “Guide to Operational Technology (OT) Security”**, NIST, 2023.
- **ISA/IEC 62443 series** – international standard for industrial automation and control systems security (zones & conduits, security levels).
- **MITRE ATT&CK for ICS** – matrix of adversary tactics and techniques specific to OT/ICS.

Threat Landscape Reports (optional reading)

- ENISA Threat Landscape 2024 – key trends for critical sectors.
- KPMG / Cisco reports on OT threat landscape and NIS2 implementation for critical infrastructure.

My own ongoing research : SECURAIL MTI Chair

From ICS to OT: what are we really protecting?



- Historically, the focus was on Industrial Control Systems (ICS):
 - SCADA, DCS, PLCs controlling industrial processes.
- Today, the broader term Operational Technology (OT) is used in standards such as NIST SP 800-82 Revision 3.
- OT includes:
 - Industrial automation and control systems (ICS/SCADA/DCS/PLC).
 - Building automation (HVAC, access control).
 - Transport systems (rail, metros, ports, airports).
 - Energy, water, and other critical infrastructures.

Lecture 1 : Industrial & OT Systems and Security Fundamentals



- What are Industrial Control Systems and Operational Technology (OT)?
- Why do OT systems need dedicated cybersecurity approaches?
- Overview of real incidents and current OT threat landscape.



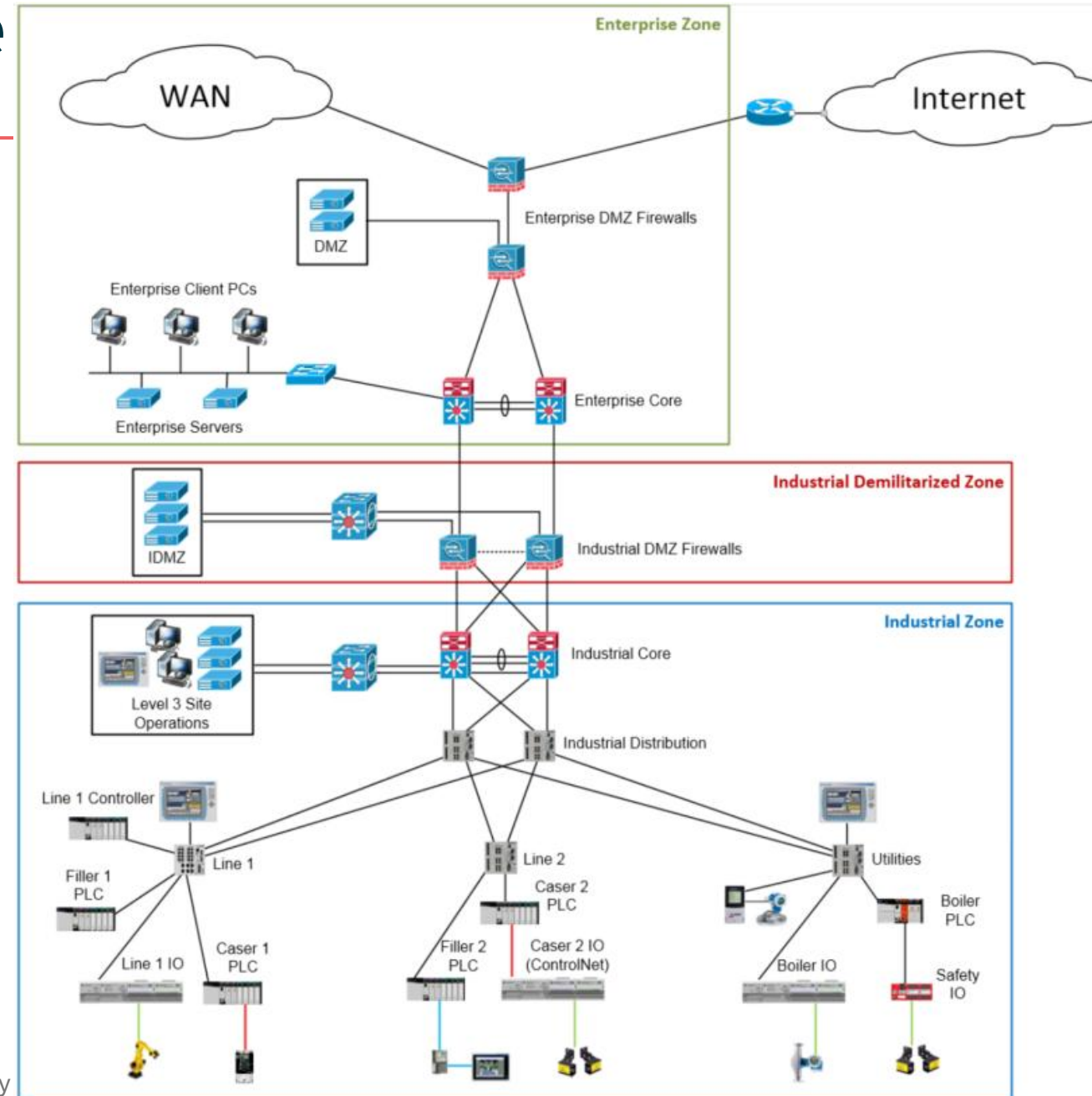
ICS/OT architecture

- The primary objective of an Industrial Control System (ICS) or OT system is to **monitor and safely control a physical process**, such as producing a product, moving trains, or delivering energy and water.
- This objective is implemented through several **functional layers** within the ICS/OT architecture that together provide supervision, control, safety, monitoring and administration of the process



ICS/OT architecture

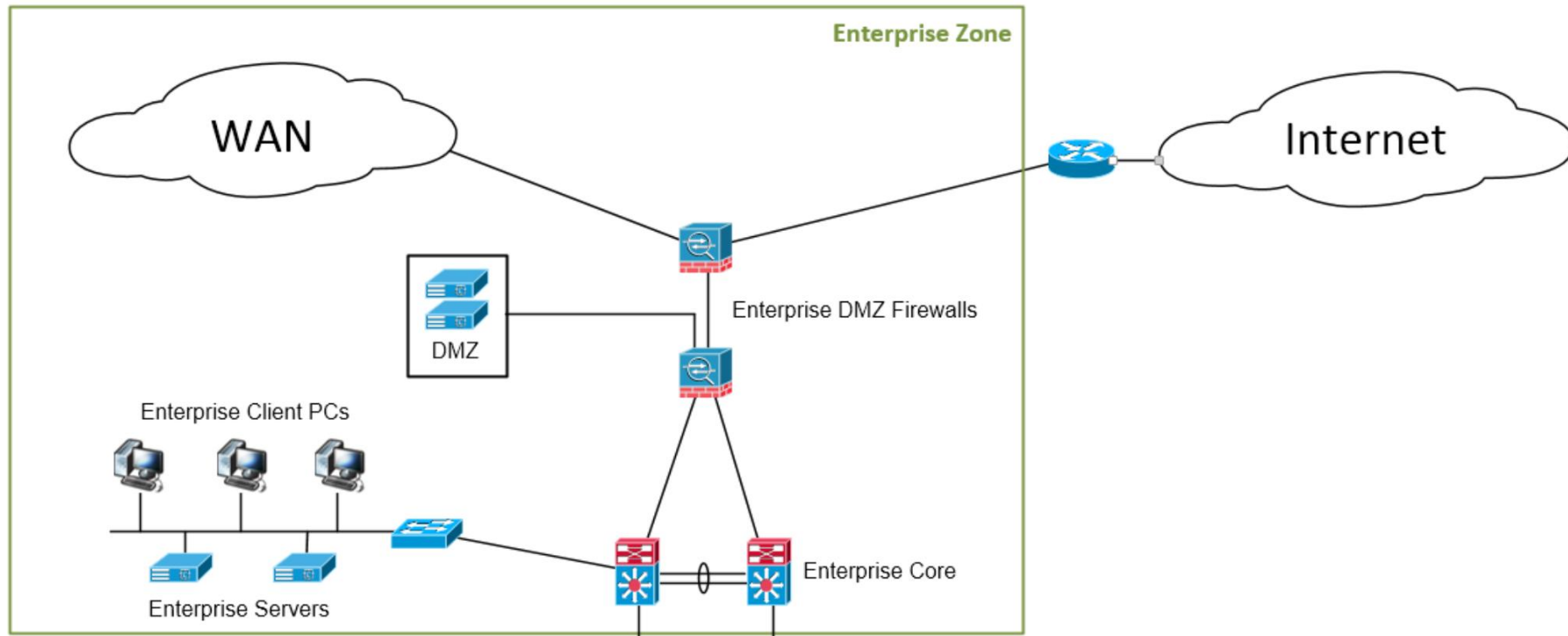
- The diagram shows a **reference ICS/OT architecture** based on the Purdue model.
- It spans the **Enterprise Zone**, the **Industrial Demilitarized Zone (IDMZ)** and the **Industrial/OT Zone**, and we will use it throughout the course when discussing threats, segmentation and monitoring.





ICS/OT architecture

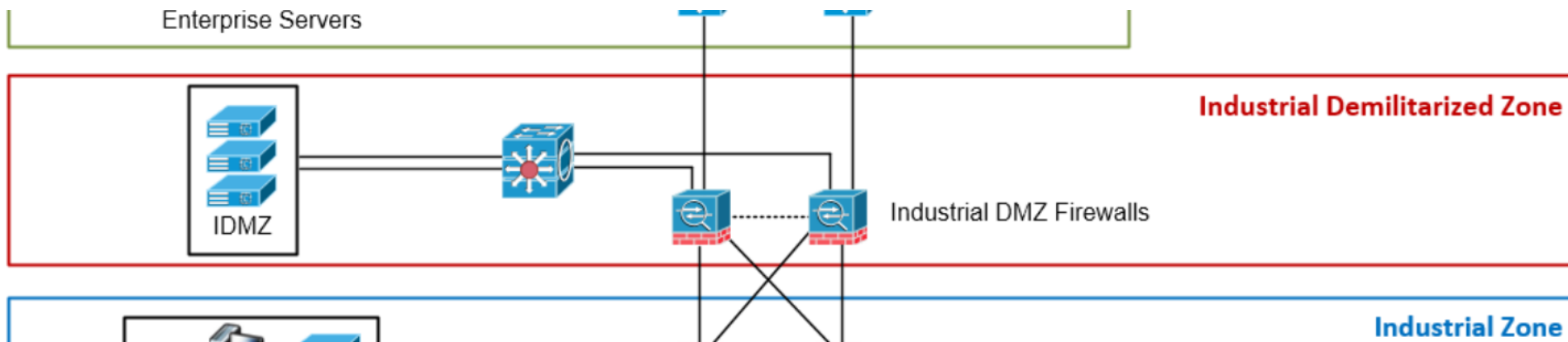
- The **Enterprise Zone** contains the classic **IT infrastructure** of the organisation: business applications, servers, workstations and laptops, as well as mobile devices.
- These systems are interconnected through Ethernet switches, routers, wireless access points and firewalls, and are typically managed according to corporate IT security policies.





ICS/OT architecture

- The **Industrial Demilitarized Zone (IDMZ)** is a **security buffer** between the Enterprise and Industrial/OT Zones.
- It usually hosts services that must communicate with both worlds (for example data historians, remote access jump servers, patch-management servers) and is built using virtualisation platforms, firewalls and tightly controlled network switches.

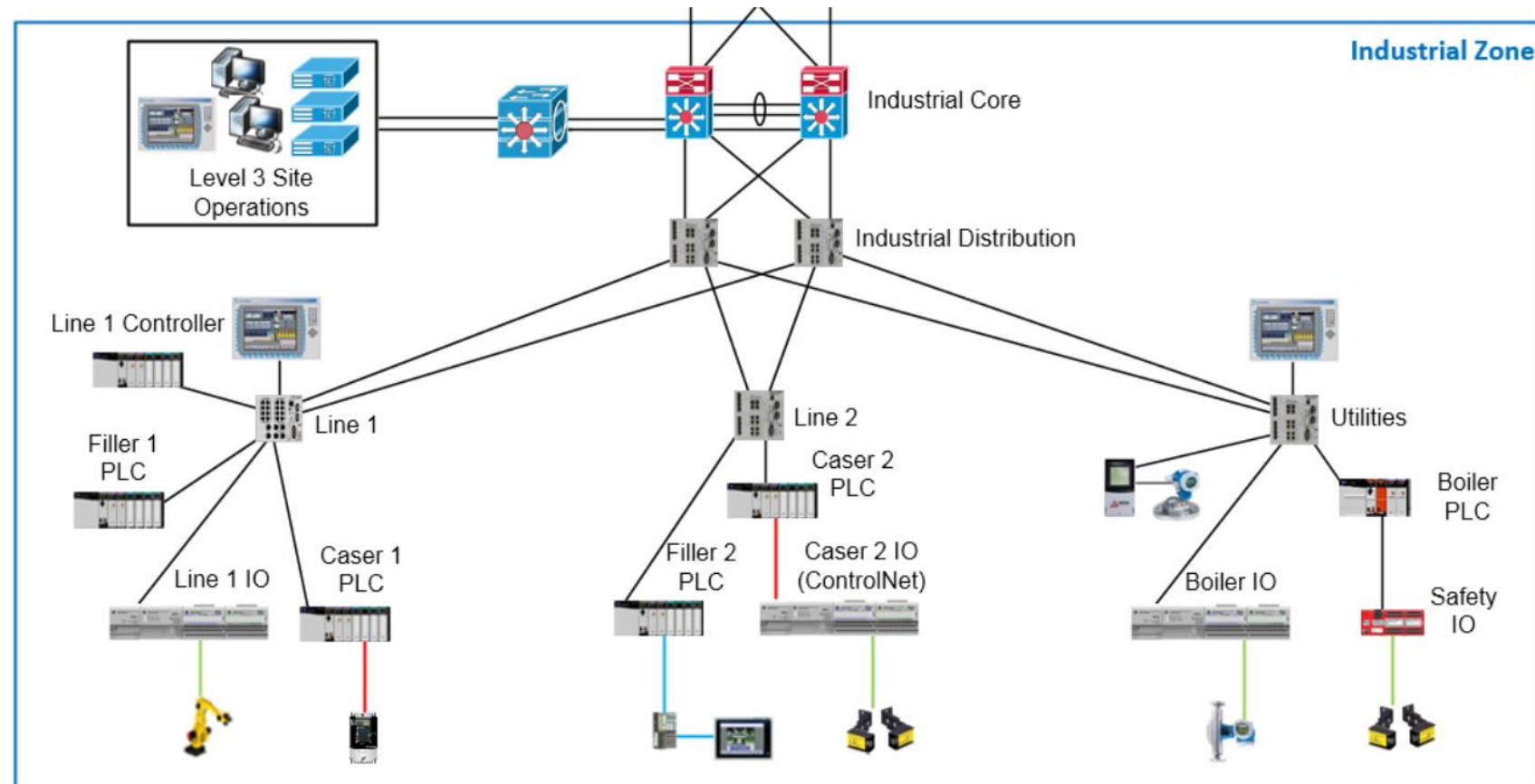




ICS/OT architecture

- The **Industrial / OT Zone** hosts the actual **control systems and field equipment**: SCADA servers, HMIs, PLCs, safety controllers, sensors and actuators.

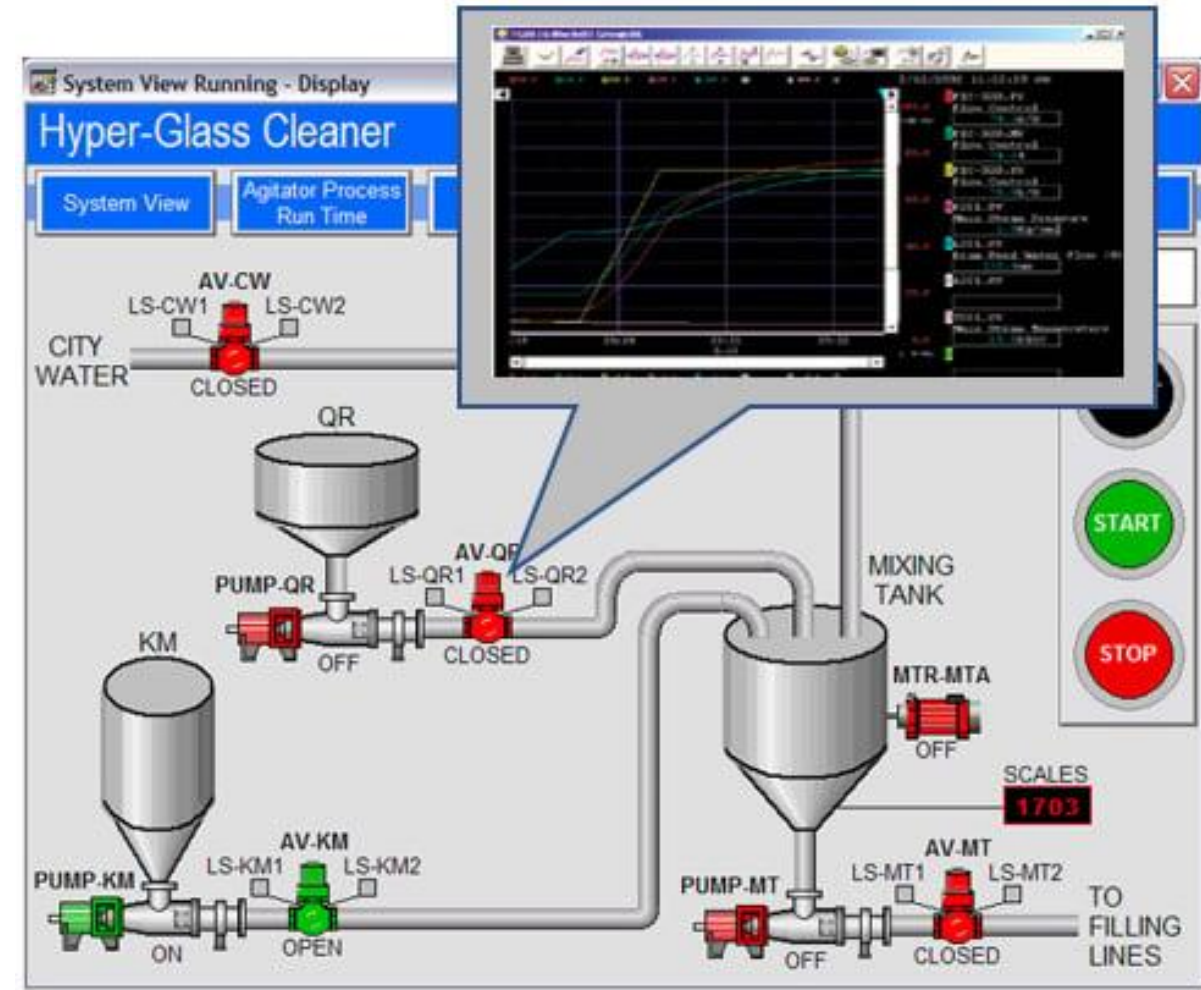
It combines standard IT components with proprietary, vendor-specific hardware.





ICS functions

- The **view function** entails observing the real-time status of the automation system.
- This information is used by operators, supervisors, maintenance engineers, or other personnel to make informed business decisions or take corrective measures.
- For instance, if an operator notices that the temperature of boiler 1 is dropping, they may opt to boost the steam supply to the boiler.
- **The view process is passive, serving as a means to present information for human response.**





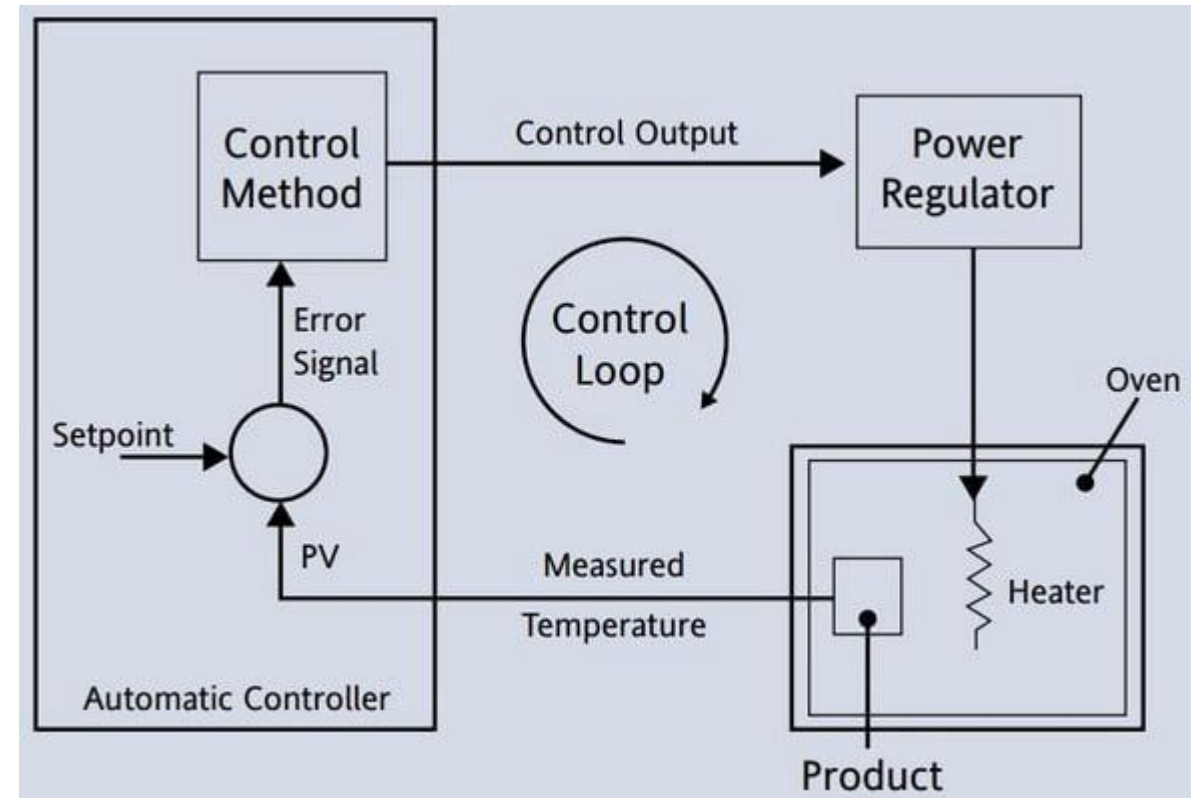
ICS functions

- The **monitor function** typically operates within a control loop, such as maintaining a consistent level in a tank.
- It monitors critical parameters such as pressure, temperature, or level, comparing them against preset thresholds, and triggers alerts or actions as per its configuration.
- Unlike the view function, the monitor function **automates** the determination of deviations, which can prompt responses ranging from an alarm notification to initiating a complete system shutdown procedure.

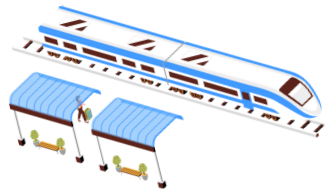


ICS functions

- The **control function** is responsible for manipulation, movement, activation, and initiation of actions.
- It's the system that activates actuators, opens valves, runs motors, and so on.
- Control actions may be **triggered** by an **operator** via button presses or **setpoint adjustments on a Human-Machine Interface (HMI)** screen, or they can occur **automatically** as part of the process control.



ICS/OT functions: why does it matter in a world of encrypted protocols?



- In modern IT networks, it may seem hard to manipulate traffic because many applications use encrypted and authenticated protocols over switched Ethernet. **Most ICS/OT networks are different.**
- In OT environments, **availability and safety often take priority over confidentiality and integrity**, so legacy devices and protocols are kept in service for decades, often with minimal built-in security.
- Many widely used ICS/OT communication protocols (e.g. Modbus, classic DNP3, PROFINET/PROFIBUS, legacy Siemens S7, OPC DA) were designed for isolated, trusted networks and **lack native cryptographic protections** such as authentication, integrity checks or encryption.
- As a result, even when these protocols are carried over modern Ethernet, an attacker with access to the OT network can still **observe, replay, spoof or modify control traffic** unless additional security measures (segmentation, secure gateways, protocol-aware firewalls, monitoring) are put in place.



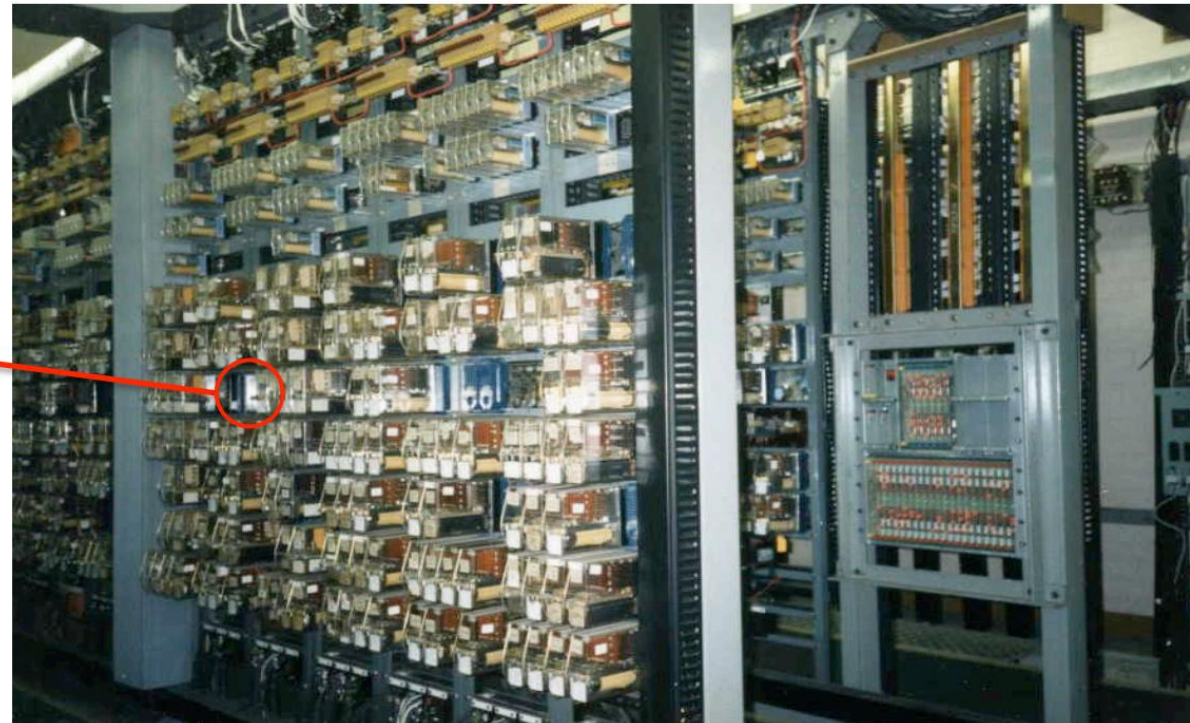
Evolution of ICS systems

Prior to computer-based control systems, **relays** were used for automating equipment on assembly lines. They were assembled manually, making them expensive, and any program changes necessitated **labor-intensive** rewiring.

Individual relay as an automatic logic switch



Huge relay panel. Today this panel might only take a few lines of code to replicate.



<https://en.wikipedia.org/wiki/Relay>



Evolution of ICS systems : PLC

In 1968, Dick Morley and Dodd Bedford & Associates Lawyers proposed a solid-state system, later known as the PLC, meeting requirements for flexibility, affordability, and compatibility with relay logic, revolutionizing industrial automation.

- Early PLC models supported input and output signals, internal logic with relay coils and contacts, timers, and counters.
- Programming was initially conducted using **proprietary software** on personal computers, communicating via **proprietary media and protocols**.
- Over time, both the functionality of PLCs and the programming devices evolved, along with their communication methods.



¹Modicon: Modular Digital CONTroller ²PLC: Programmable Logic Controllers



Evolution of ICS systems : Communication protocols

PCs running Windows-based programming applications became standard for programming PLCs, facilitating easier programming, testing, and troubleshooting. to Ethernet-based networks.

- Initially, communication relied on the **Modbus** protocol via RS-232 serial communication, later expanding to include protocols like RS-485, DeviceNet, and **PROFIBUS**.
- These protocols enabled networking PLCs with other devices like motor drives and HMIs.**
- Recently, **Ethernet** and protocols like **Ethernet/IP** and **PROFINET** have become popular, transitioning PLC communication from serial to Ethernet-based networks.

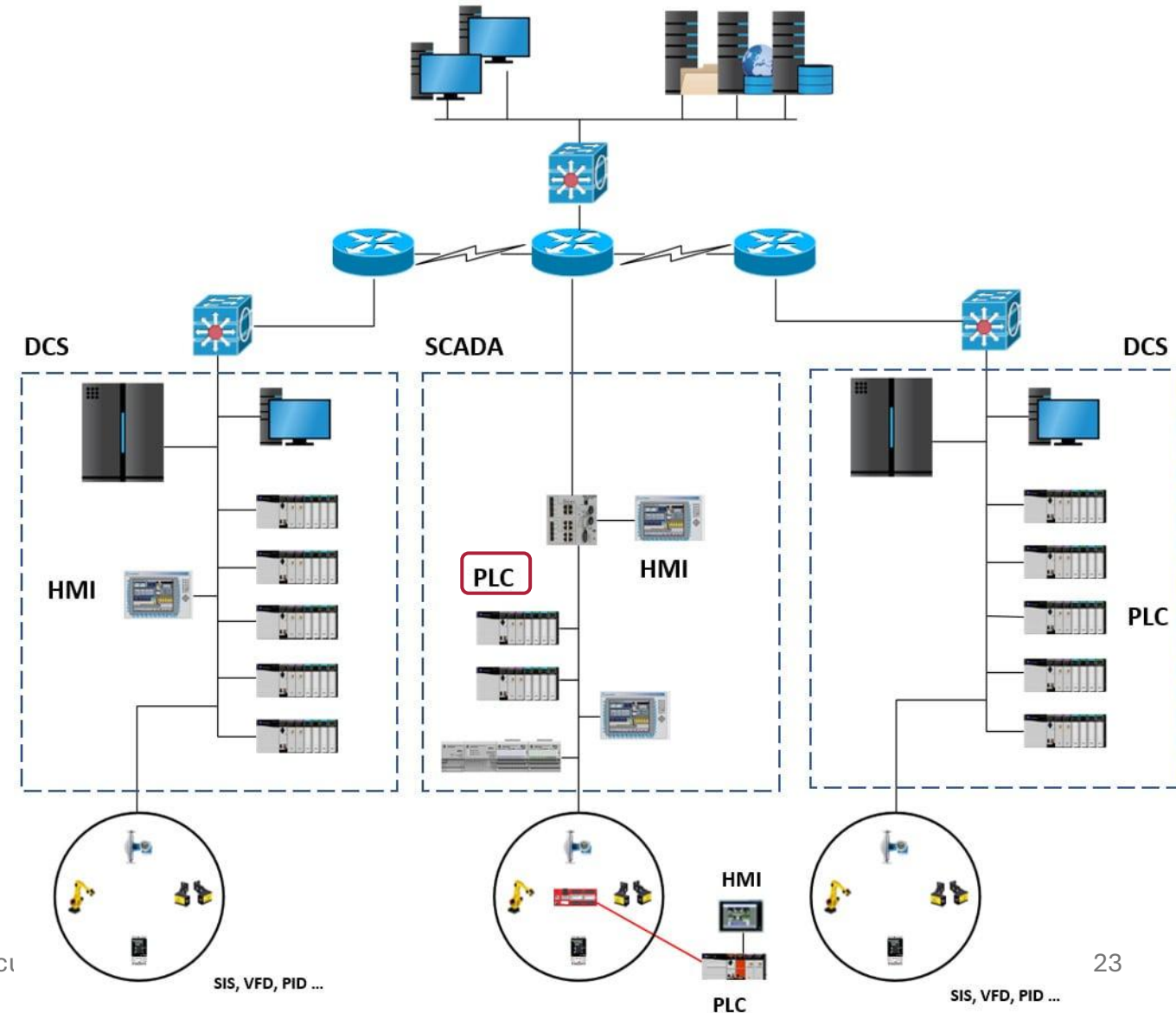
A small Allen Bradley PLC with processor and I/O cards





From small to large systems

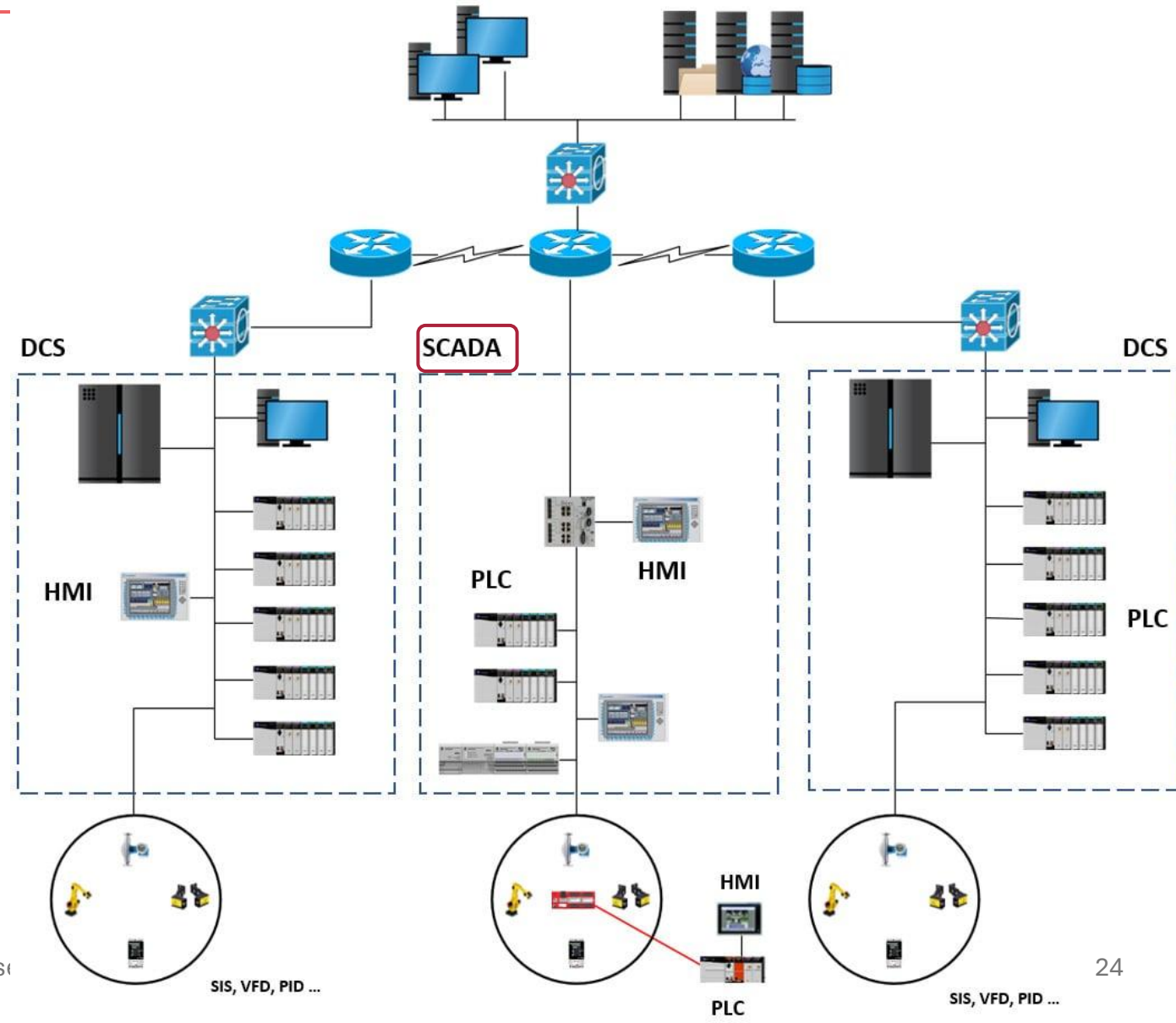
PLCs are commonly employed to **manage relatively small** processes, such as individual sections of an assembly line or processes with a limited number of components, typically ranging from **a few to a few hundred Input/Output (I/O) points each**.





From small to large systems

SCADA (Supervisory Control And Data Acquisition) involves the **networking of multiple PLCs** to control numerous small processes, often extending to remote sites.

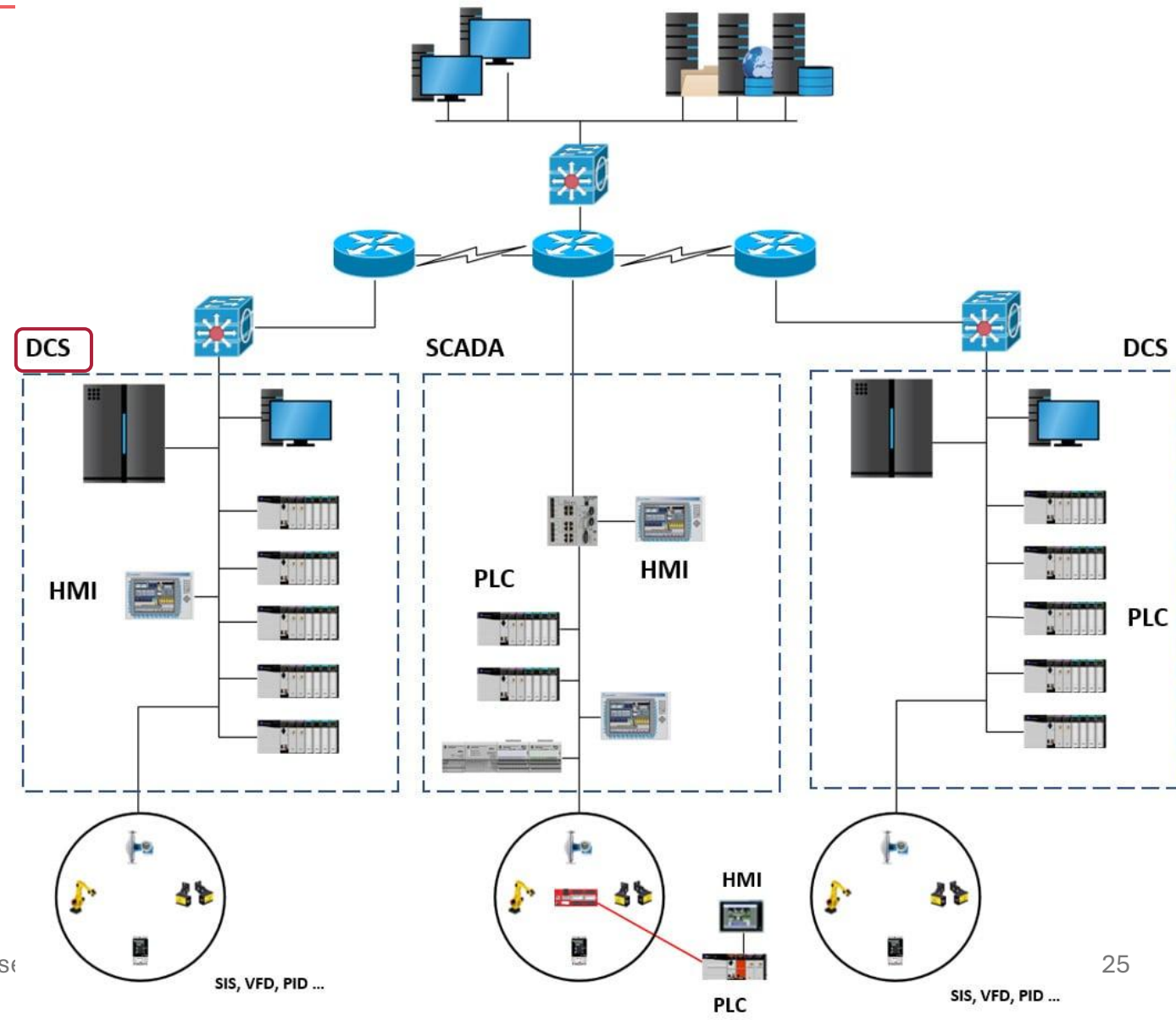




From small to large systems

DCS (Distributed Control System) is utilized for larger processes, like power generation, or centralized plant-wide control.

It operates through Distributed Processing Units (DPU) on a dedicated network, with each DPU managing thousands of I/O points.

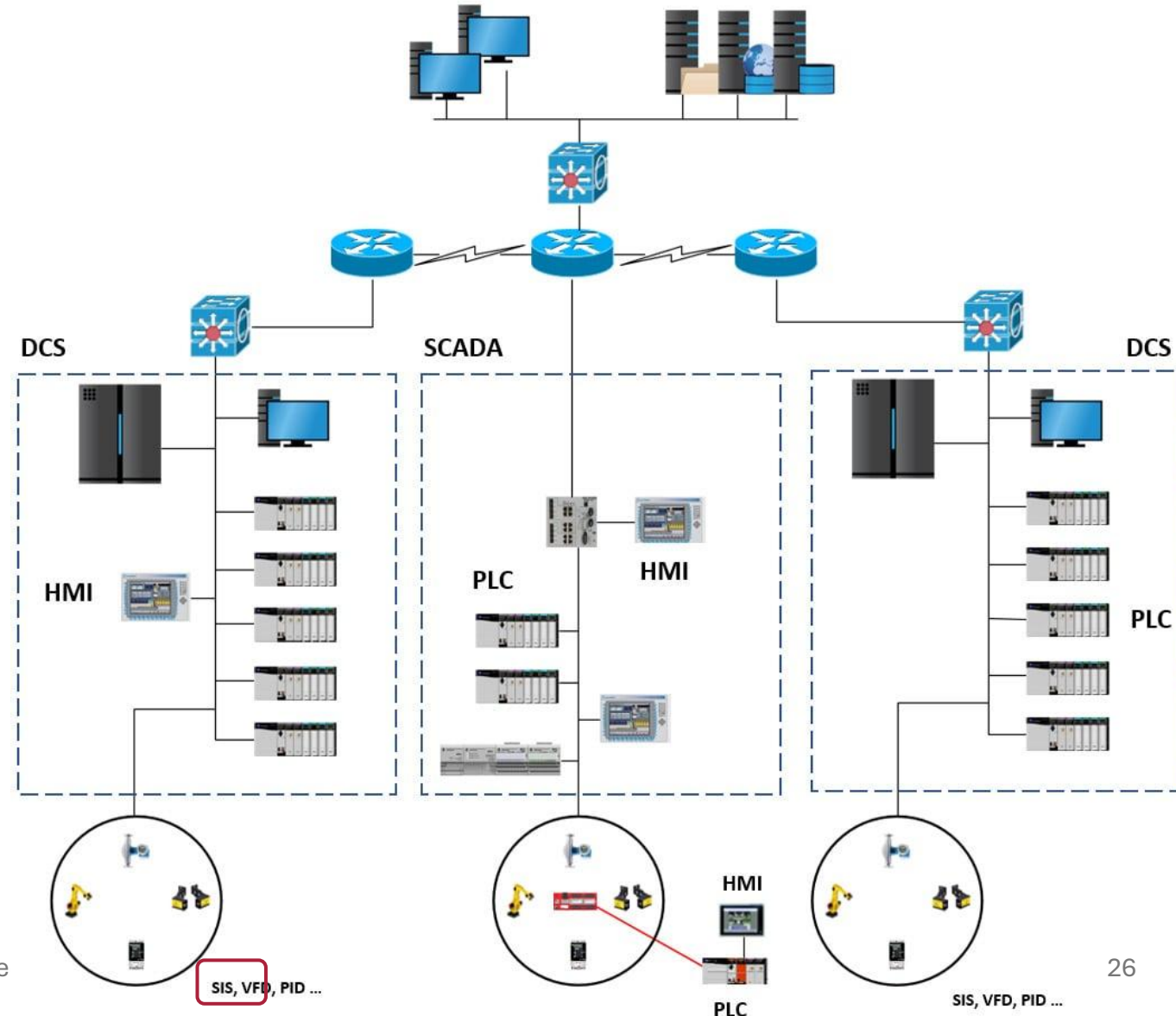




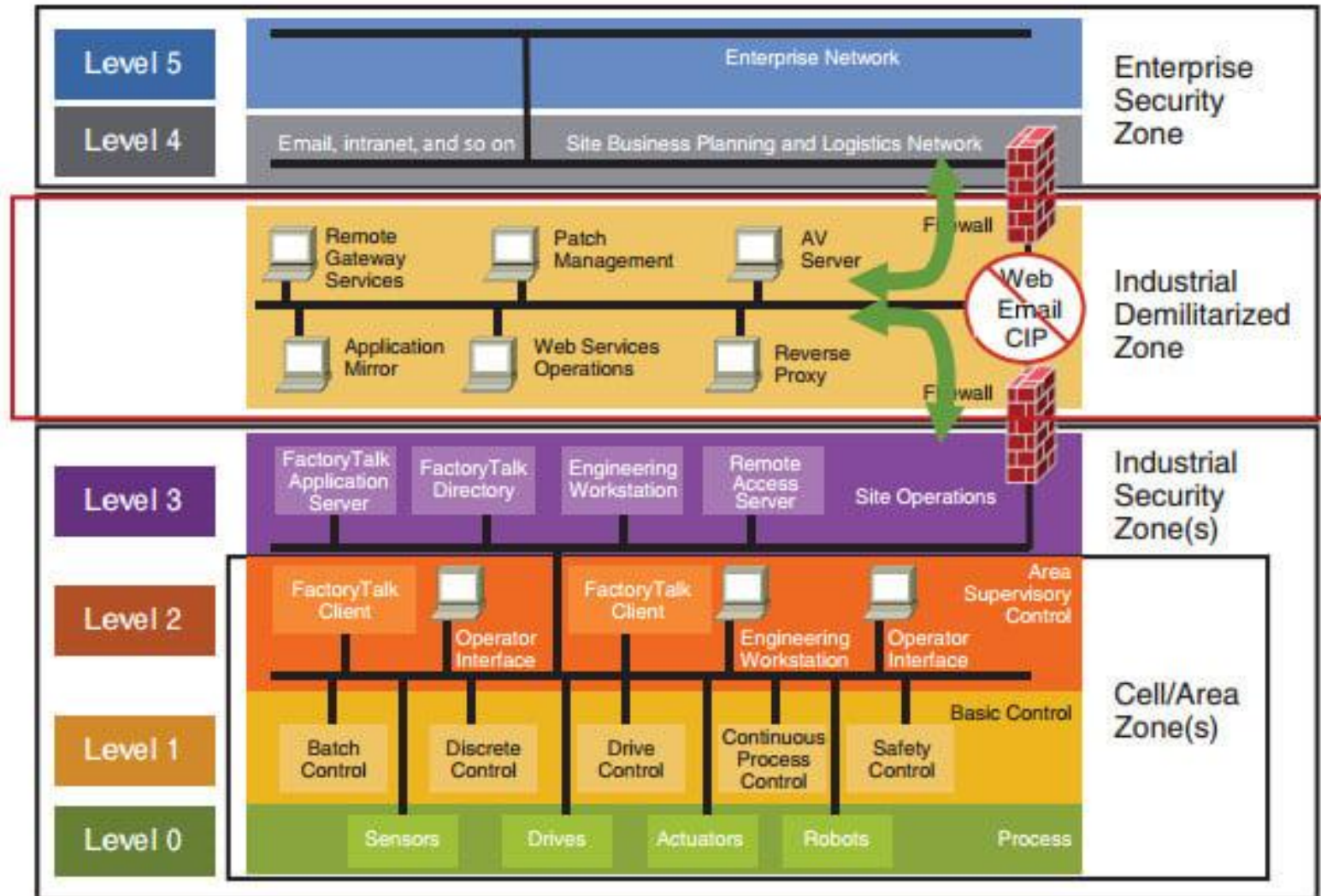
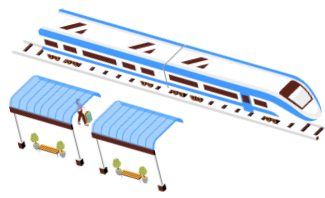
From small to large systems

SIS (Safety Instrumented Systems) are dedicated **safety monitoring** systems that ensure secure shutdown or transition of monitored systems in hardware failure scenarios.

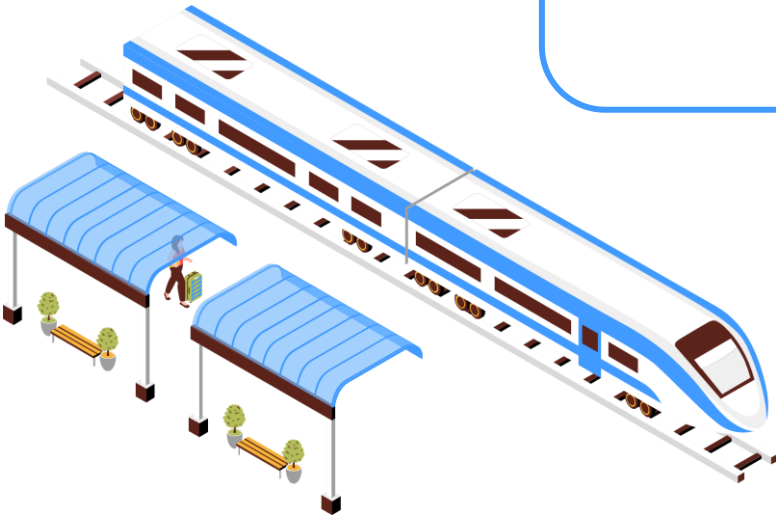
Utilizing voting mechanisms, they evaluate system performance, with Emergency Shutdown (ESD) systems being one example configured to stop machine processes upon detecting hazardous conditions.



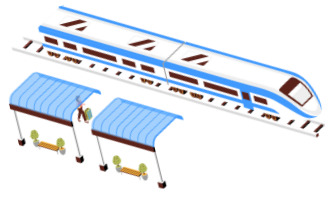
Tying all these components together : Purdue Model



IT Security : Objectives and differences with OT



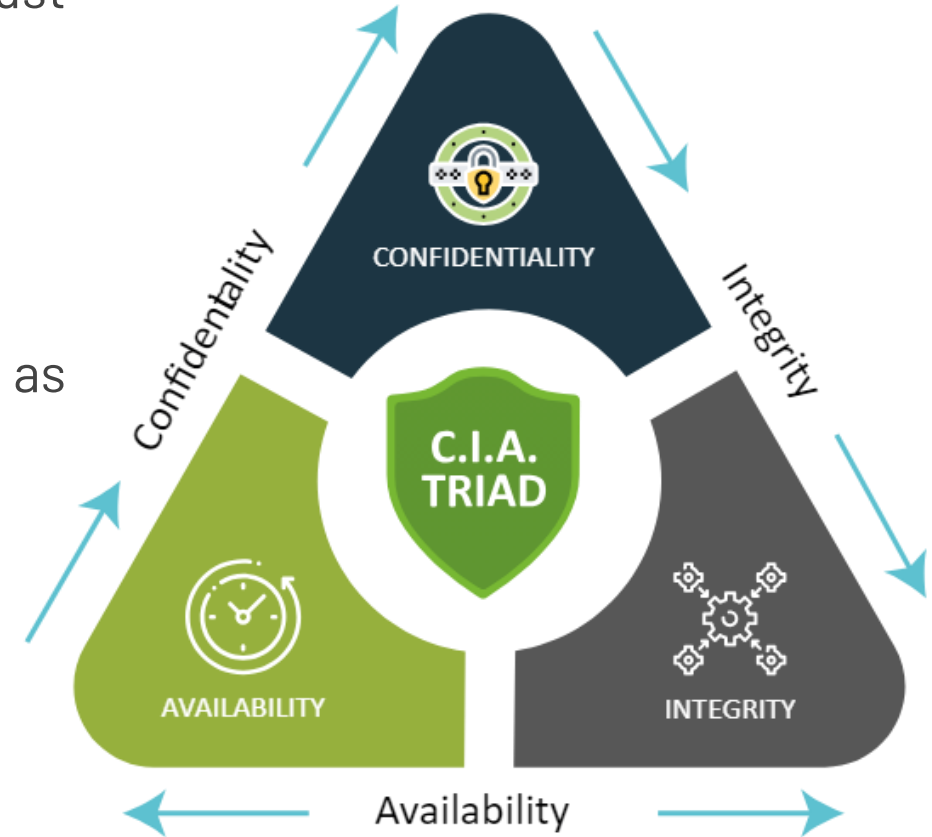
Security objectives : CIA triad



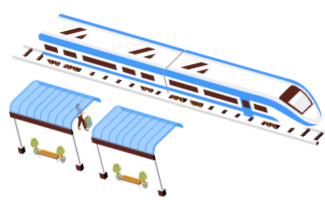
In IT security, there are three essential properties that a system must ensure:

- the **availability (A)** of services,
- the **integrity (I)** of software and data,
- and the **confidentiality (C)** of information.

These are commonly referred to as the **CIA triad** and are regarded as objectives for security measures to attain.



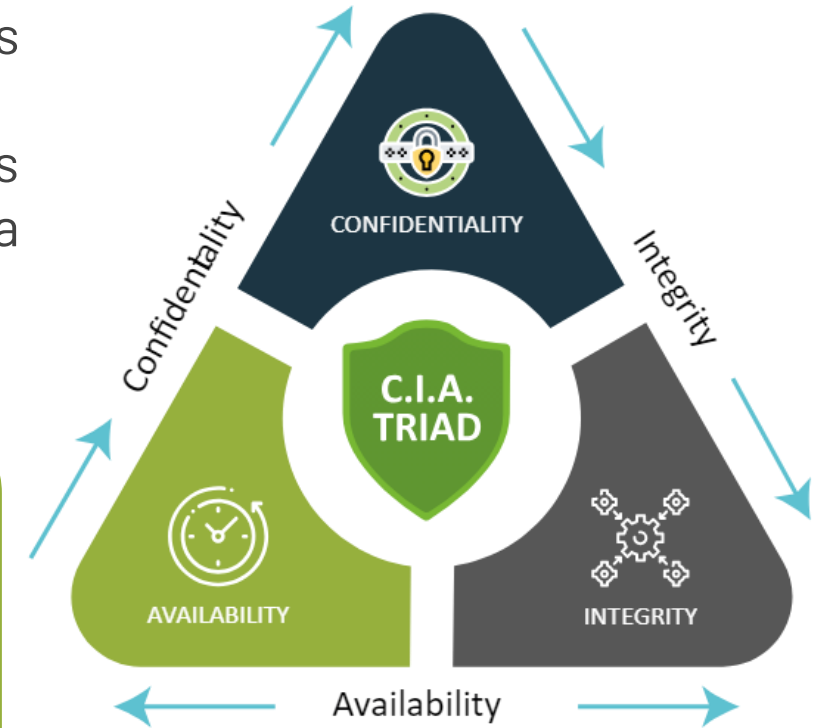
Security objectives : CIA triad



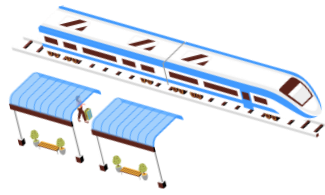
- The **Availability** of a service or information is crucial, for instance when individuals require web services from their devices.
- Its importance varies depending on the context and the user's situation.
- For example, the absence of a mapping service may not be as critical when viewing a documentary compared to being lost in a city while abroad and at night.

Regarding the **availability** in OT, it's important to differentiate between:

- Control functions operating in real-time or near real-time.
- Safety functions.
- Functions dedicated to analyzing and consolidating production data in connection with the IT domain.



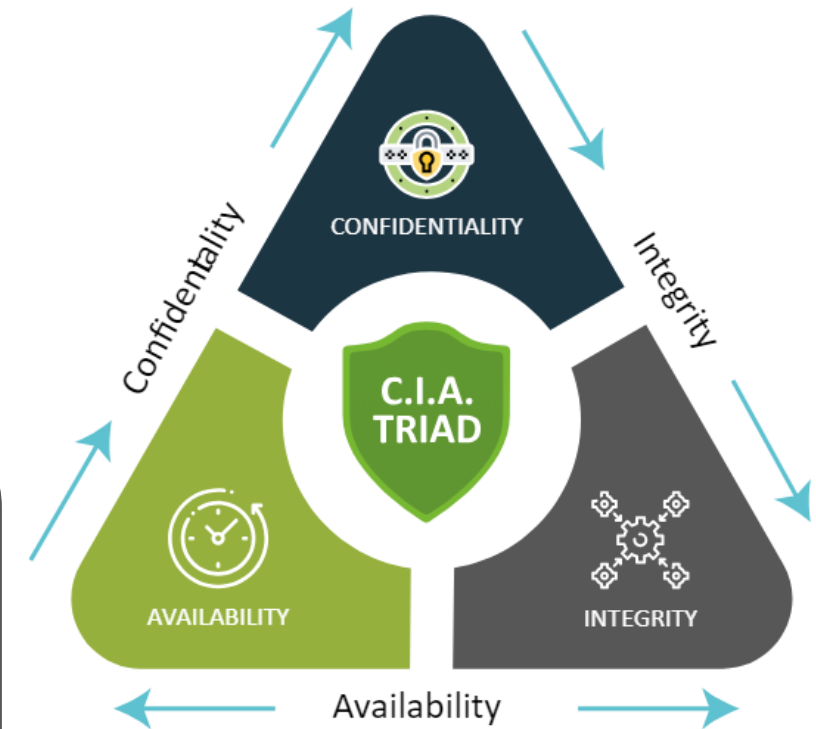
Security objectives : CIA triad



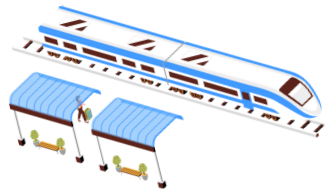
- The second criterion focuses on preserving the **integrity of data and software** against various threats like malicious acts, human errors, hardware failures, or natural disasters.
- Traditional methods used to ensure data integrity include integrity checks, data duplication or backups, and redundancy in storage or processing systems.

In ICS, **integrity** extends to :

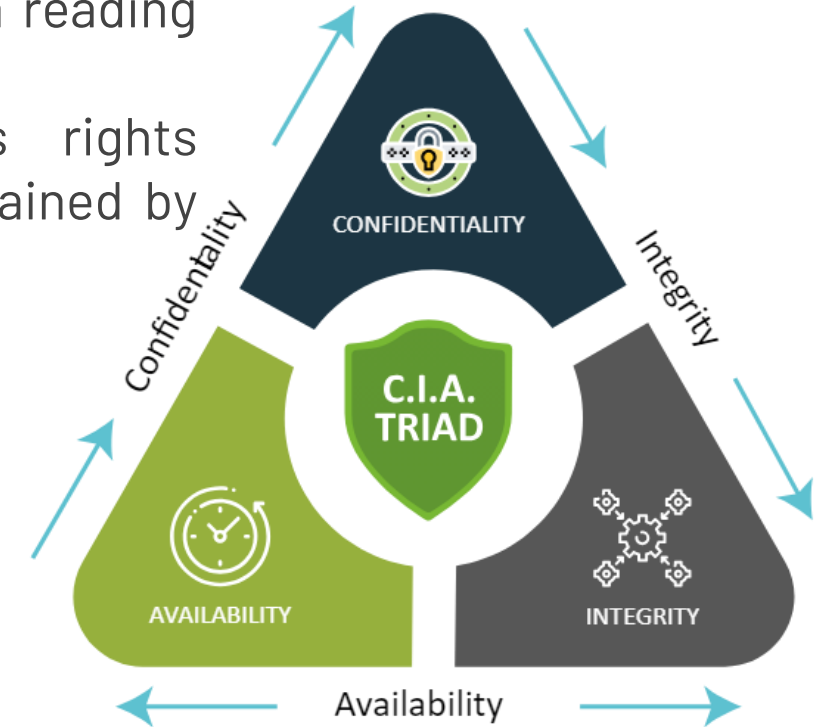
- Configurations and programs of devices such as PLCs or acquisition systems;
- SCADA and historian system configurations;
- The data stored in the PLC memory, updated in real time and representing the status of the cyber-physical system;
- Permanently stored data, which comes from measurements of the parameters of the cyber-physical system (historical).



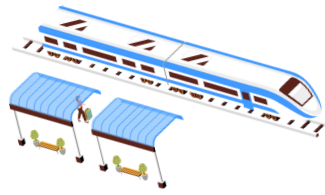
Security objectives : CIA triad



- The third criterion is **confidentiality**.
- It is linked to the maintenance of secrecy and is obtained by a reading protection.
- Confidentiality is related to authentication and access rights management to control who can read data. It can also be obtained by encrypting data using a cryptographic algorithm.



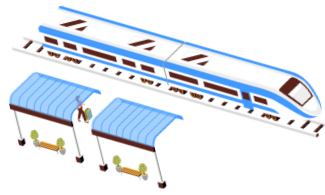
Differences between IT and OT systems



To examine the disparities in cybersecurity between the **Operational Technology (OT) and Information Technology (IT) realms**, we will assess four dimensions:

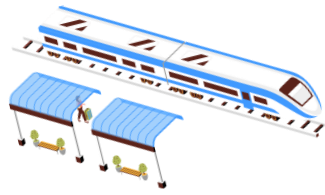
- The expected functionalities;
- The technology used;
- The lifecycle of the system;
- Security management.

Differences between IT and OT systems : Functionalities



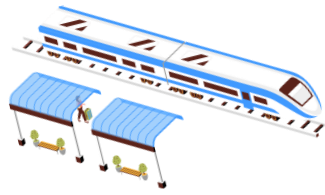
- ICSs, unlike IT systems **confined to handling data in a digital realm**, are utilized to monitor and take action within physical systems.
- They serve dual functions: ensuring optimal control as per planned operations and providing safety measures during abnormal operations.
- Under normal control, an **ICS acquires and stores sensor data**, regulates parameters to desired values, and controls the physical system according to predefined sequences for production.
- In terms of safety functions (SIS), the ICS detects deviations that jeopardize the security of the physical system or its surroundings, executing actions to safeguard it.
- This may involve detecting temperature or pressure thresholds, hazardous positions, and initiating actions like opening valves, triggering cooling, or halting operations.
- ICSs operate in **real-time or near-real-time**, with responsiveness closely tied to the physical world's pace.
- Availability, the capability to execute a function promptly, **is crucial for ICSs, especially concerning security functions.**

Differences between IT and OT systems : Technology



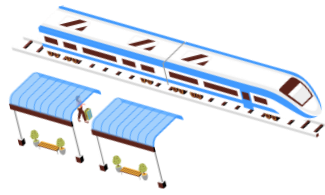
- Unlike IT systems, which are mainly composed of computer workstations, servers and network equipment of controlled and relatively recent quality, ICSs/OT are based on a variety of equipment that can be built from standard modules (COTS) or be quite old.
- The various field equipment directly connected to the physical system are mainly PLCs and embedded systems. These are designed primarily to provide efficient real-time functions and offer limited support for security or centralized administration.

Differences between IT and OT systems : Lifecycle



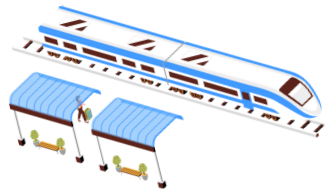
- The design of an ICS occurs alongside **the installation process**, typically spanning its lifespan, which can extend up to **20 years**. However, this static nature impedes its ability to adapt to evolving threats and incorporate modern security measures, such as data encryption between devices.
- An ICS must operate **24 h a day, 7 days a week** and few facilities have a test platform.
→ Security updates are therefore difficult to deploy. This compares to the approach of large software vendors, for whom security is crucial, and who provide security patches quickly.

Differences between IT and OT systems : Security management



- Industrial installations pose **risks to employees**, the environment, and nearby populations, with potential equipment malfunction or breakdown impacting production quantity or quality.
- Risk analysis, often mandatory for high-risk installations, ensures **operational safety**.
- Many companies use security management systems, distinct from IT security managed by the IT department, typically focusing on implementing best practices rather than systematic risk analysis.
- This division often results in limited awareness of IT security risks in the OT domain, reflecting in access management practices.

Differences between IT and OT systems : summary



Information Systems

Confidentiality

Integrity Program
Data

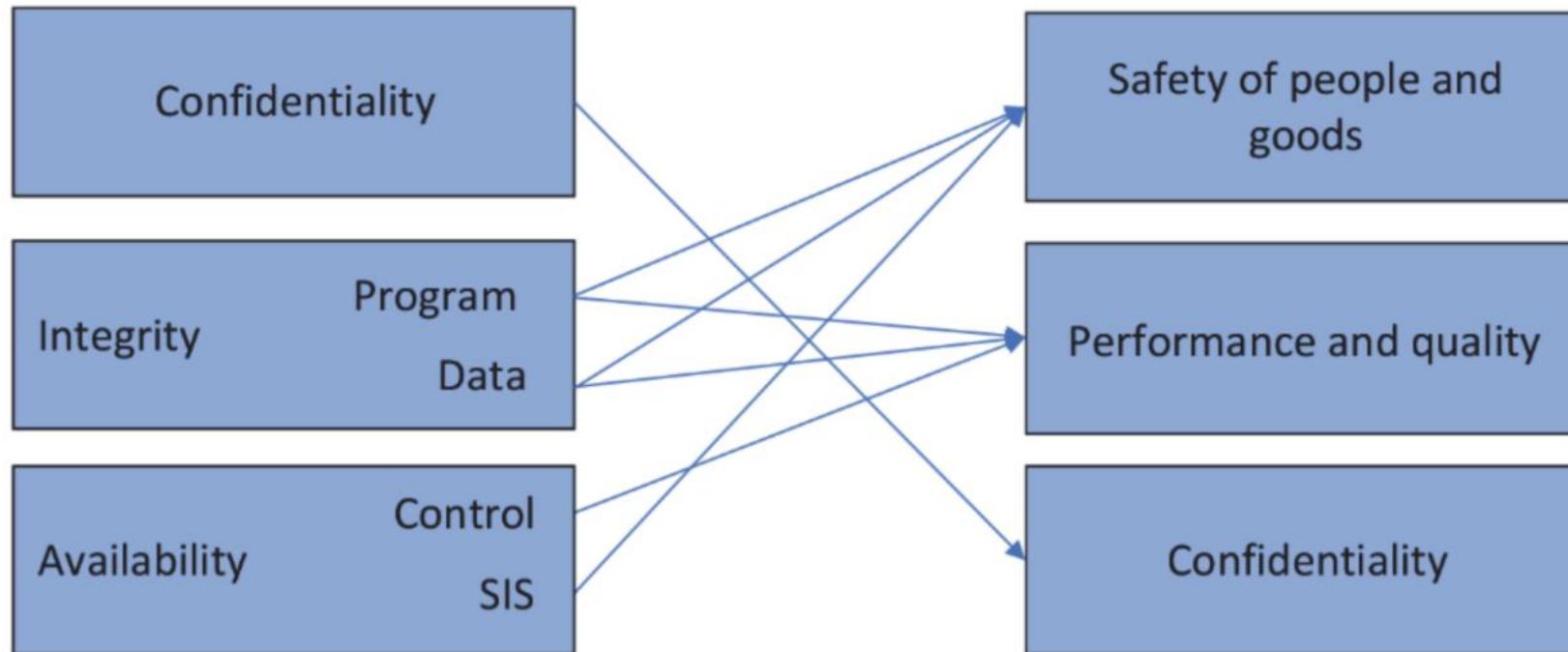
Availability Control
SIS

Industrial Control Systems

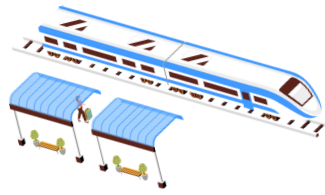
Safety of people and goods

Performance and quality

Confidentiality

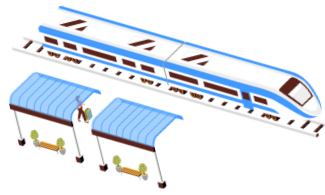


Differences between IT and OT systems : summary



- Any discussion of industrial security needs to factor in the pillars of information assurance (IA), in addition to physical safety and resiliency.
- In ICS, the confidentiality and integrity of data is as relevant as the resiliency of controls and the safety of physical assets and people.
- In this context, let's define the pillars of ICS security as follows:
 - **Confidentiality:** Protecting sensitive information from disclosure and maintaining data privacy
 - **Integrity:** Information is not modified, accidentally or purposefully, without being detected
 - **Authentication:** Data is accessed by known entities, while making sure that that data belongs to a known identity or endpoint (this generally follows identification)
 - **Non-repudiation:** Ensuring that an individual or system cannot later deny having performed an action
 - **Availability:** Ensuring that information is available when needed

Differences between IT and OT systems : summary

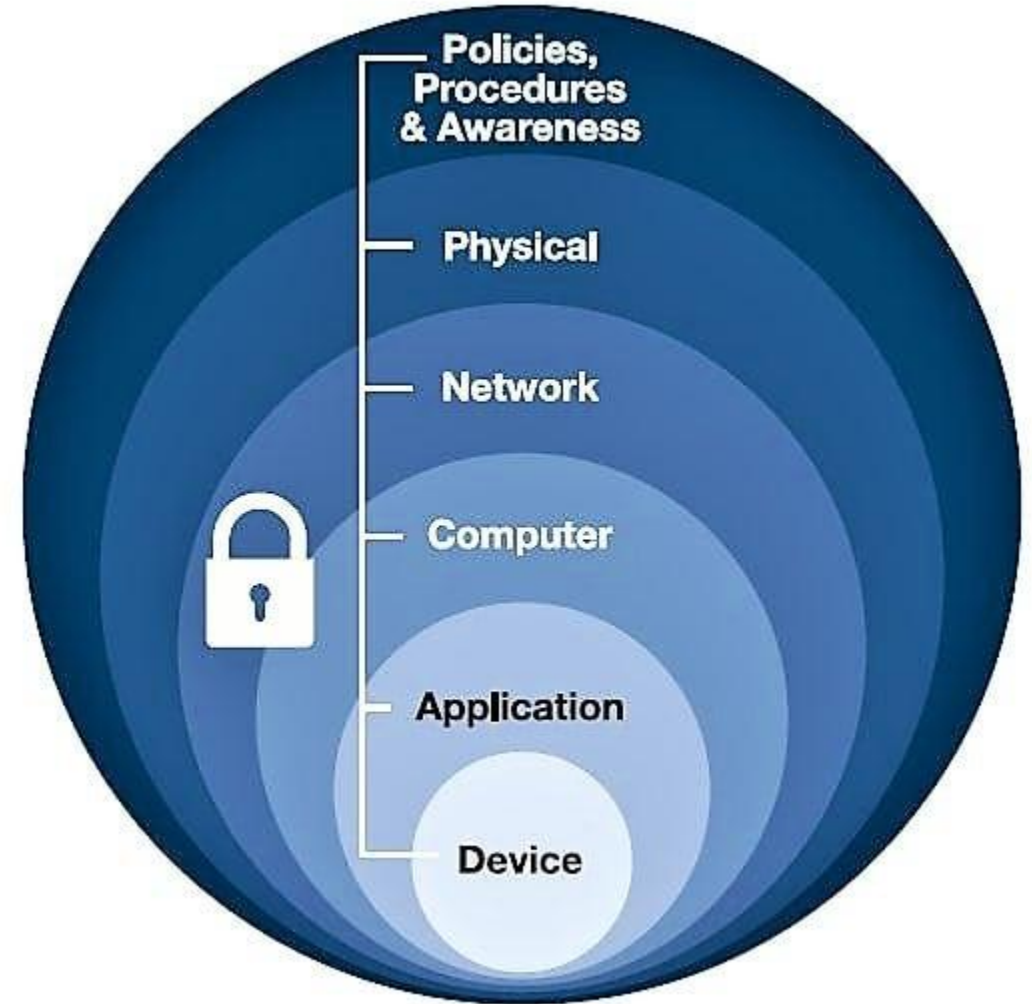


- Any discussion of industrial security needs to factor in the pillars of information assurance (IA), in addition to physical safety and resiliency. In ICS, the confidentiality and integrity of data is as relevant as the resiliency of controls and the safety of physical assets and people.
- In addition to these pillars, the disciplines of resiliency and safety are defined as:
- **Resilience:** Ensuring the industrial control system maintains state awareness and an accepted level of operational normalcy in response to disturbances, including threats of an unexpected and malicious nature
- **Safety:** Ensuing in the event of an attack that the affected system does not cause injury, harm, or damage to the environment or people



DiD: Defense in Depth

- **Physical:** Limit physical access for authorized personnel to cell/area zones, control panels, devices, cabling, and control rooms, through the use of locks, gates, key cards, and biometrics.
- **Network:** Security framework—for example, firewall policies, ACL policies for switches and routers, AAA, intrusion detection, and prevention systems.
- **Computer:** Patch management, anti-malware software, removal of unused applications/protocols/services, closing unnecessary logical ports, and protecting physical ports.
- **Application:** Authentication, authorization and accounting (AAA) as well as vulnerability management, patch management and secure development life cycle management.
- **Device:** Device hardening, communication encryption and restrictive access as well as patch management, device life cycle management, and configuration and change management.





ICS security restrictions

- Many IT professionals apply **traditional IT security methods to secure ICS networks.**
- While suitable for some network infrastructure and support services, standard IT security strategies are not ideal for many core ICS systems and devices.
- Various factors contribute to this disparity.



ICS security restrictions

- **Device related restrictions:** most ICS controls and automation devices are resource restrained. They are small form factor embedded devices with just enough memory and CPU cycles to get their job done.
- **Network-related restrictions** in ICS environments are significant due to the critical functions they support, often requiring continuous, real-time communications without disruptions. Implementing network security measures like firewalls or NIDS can introduce latency that may compromise processes.
- **Safety-related restrictions** are paramount in securing ICS devices and networks, as operators must swiftly interact with the system during emergencies. Complex passwords or lockout policies can hinder operator response, potentially leading to unsafe situations.
- **Runtime and uptime requirements** are crucial in ICS environments, where high uptime is essential for continuous production processes. With strict integrity requirements, any system changes may necessitate a time-consuming revalidation process, further limiting maintenance or security activities.